

ORISO DSFA v5-draft · EN · 2026-09-30

UNAPPROVED / NICHT FREIGEgeben — Unapproved review draft. Source claims and illustrative operator values need exact-version technical, operator and legal review. Annex 2 is not available.

Chapter 1

Introduction, scope and master data

Organisational part — maintained by the platform operator (contract documents) — master data from the administration area

The platform is provided by the operator and its affiliated organisations. Processing takes place under joint controllership (§ 28 KDG / Art. 26 GDPR). This DPIA exclusively concerns processing by the platform operator: provision and technical operation of the online counselling platform (hereafter “platform”).

1.1 Controller

| Controller | Deutscher Caritasverband e. V.

| Address | Karlstraße 40, 79104 Freiburg im Breisgau

| Contact | datenschutz@caritas.example · +49 761 200-0

| Data protection officer | Data Protection Office

| Competent supervisory authority | Diocesan data protection officer / State Commissioner for Data Protection — Katholisches Datenschutzzentrum Frankfurt, Hausener Weg 66, 60489 Frankfurt am Main

1.2 Annexes

Annex 1 — risk analysis (extract in Chapter 10) · Annex 2 — deletion concept (both maintained as separate documents with corresponding versions; status of this edition: in preparation).

1.3 Reassessment

This DPIA is reviewed routinely; next date: 01 June 2027. The review history corresponds to the document history (see version block); each version remains accessible at its version URL, while latest points to the current edition.

Chapter 2

Threshold analysis

Result DPIA required — carried out

Preliminary questions Is the processing included in the list of operations for which the competent supervisory authority requires a DPIA (“mandatory list”) ? Section 35(5) KDG / Article 35(4) GDPR: No Does a statutory example apply in which the law presumes a high risk? Section 35(4) KDG / Article 35(3) GDPR: Yes

Assessment questions (WP 248 criteria) — a DPIA is required if two or more answers are yes Are data subjects evaluated or classified (scoring, profiling)? No Are automated decisions made with legal effects or similarly significant adverse effects? No Are data subjects systematically monitored? No Are confidential, highly personal data or special categories of personal data processed? Yes Is processing carried out on a large scale? Yes Are datasets matched or combined? No Are vulnerable data subjects involved, or do several controllers cooperate? Yes Are innovative technologies used in a novel way? No Does processing prevent data subjects from exercising a right? No Does processing take place in publicly accessible locations? No

A DPIA must be carried out: special categories of personal data under Section 11 KDG / Article 9 GDPR are expected, the platform serves a large number of people seeking advice, some particularly vulnerable, and several controllers cooperate.

Technical part — maintained by ORISO — the result paragraph in 2.3 is organisational —

Before carrying out a data protection impact assessment (“DPIA”), it must be assessed whether the processing activity is likely to result in a high risk to the rights and freedoms of natural persons, making a DPIA mandatory under Section 35 KDG / Article 35 GDPR. Assessment has two stages: first the two preliminary questions (the competent supervisory authority’s mandatory list and statutory examples), then the ten assessment questions corresponding to the criteria of the Article 29 Working Party (WP 248).

2.1 Preliminary questions

The statutory example applies because processing involves substantial amounts of special categories of personal data under Section 11 KDG / Article 9 GDPR — particularly health data, information about sex life, religious or philosophical beliefs — and also addresses a population that is partly particularly vulnerable.

Note on the compliance preset. Under the General Data Protection Regulation, the reasoning follows a different route: online counselling concerning crises and health through digital channels is generally already included in the mandatory lists of the competent state data protection authorities, so the first preliminary question is answered yes there. The threshold analysis has the same result under both regimes; only the chain of reasoning changes.

2.2 Assessment questions

The decision rule is: if two or more questions are answered yes, a DPIA is required.

Question 4. Counselling inherently concerns confidential content; depending on the specialist area, health data and information about substance use, pregnancy, domestic violence or suicidal tendencies are expected. The scope of collection is controlled for each specialist area through the counselling-type configuration (including age, gender, federal state, substances and reason for seeking advice); the platform stores these details in structured form alongside the counselling session. Counselling topics additionally involve categorising information that can itself reveal the reason for seeking advice.

Question 5. The platform is designed as a multi-tenant service for numerous organisations, counselling centres and specialist areas; the numbers of registered advice seekers, counselling centres and active counsellors are stated in Chapter 3 with a reporting date. The scale of the population reached already indicates increased risk.

Question 7. Several controllers cooperate (platform operator, organisations and counselling centres; see Chapter 5). At the same time, some specialist areas explicitly address vulnerable groups, particularly minors and young adults and people experiencing acute crises or dependency.

Question 8 — distinction. The technologies used (the Matrix protocol with Olm/Megolm end-to-end encryption, WebRTC video communication through a self-operated media relay and central identity management) are established, open-source standard technologies in widespread use. They are

used here as intended, rather than in a novel manner; this question is therefore answered no. Their use reduces risk and is described in detail in Chapter 6.

Question 3 — distinction. No systematic monitoring takes place: there are no tracking or analytics services, advertising networks, external fonts or third-party scripts; no product or error telemetry is collected in users' browsers. Nevertheless, transparency requires acknowledging that platform operation processes behavioural and presence metadata — notification read times, online status (presence) in the chat service, read receipts and activity times — without combining these to evaluate or monitor individuals. The processing concerned and the planned minimisation measures are described in Sections 6.10, 6.12 and 6.14.

2.3 Result

Three of the ten assessment questions are answered yes, exceeding the decision-rule threshold. A DPIA must be carried out. The decisive factors are the expected special categories of personal data under Section 11 KDG / Article 9 GDPR, the large scale of processing and cooperation between several controllers involving a partly particularly vulnerable population. This DPIA fulfils that obligation.

The result paragraph also records the operator's own assessment of the remaining risk; the operator-specific version is maintained through the free-text slot resultParagraph.

Organisational part — maintained by the platform operator (contractual documents) — editing in the administration area will follow —

This section describes the organisation, decision-making processes and legal balancing by the organisation. It cannot be derived from source code and is therefore not maintained by ORISO. Until the organisation writes it, the document contains only the draft text, originally collapsed; the square brackets deliberately mark open fields.

Show draft text

Three of the ten assessment questions are answered yes; the threshold is therefore exceeded and a data protection impact assessment must be carried out. The decisive factors are the expected special categories of personal data under Section 11 KDG / Article 9 GDPR, the large scale of processing — as at [date], [number] registered advice seekers in [number] counselling centres — and cooperation between several controllers involving a partly particularly vulnerable population. [Additional controller assessment, e.g. risk classification or special features of individual specialist areas.] This DPIA fulfils that obligation; its result is recorded in Chapter 10.

Chapter 3

Context and key figures

Organisational part — maintained by the platform operator (contract documents) — figures from the administration area

The platform connects online and face-to-face counselling (blended counselling). Access is browser-based; services comprise messages and files, voice messages, group chats, video counselling and an anonymous live individual chat.

12 affiliated organisations

148 counselling centres

412 active counsellors

9,640 registered advice-seekers

Reference date: 01 August 2026 · Figures contain aggregates only — no case or individual data.

Chapter 4

Actors, roles and governance

Technical part — maintained by ORISO — Section 4.5 is organisational —

Partners, organisations and the operator jointly decide on the purposes and means of processing; a joint-controller agreement exists (Section 28(1), sentence 2 KDG / Article 26(1) GDPR).

Organisations and counselling centres remain responsible for professional counselling, including case documentation outside the platform. The platform digitally supports conclusion of data processing agreements with organisations; organisation representatives sign through personalised, tokenised links without themselves being users of the counselling application.

[Operator's governance description: cooperation structure, bodies, decision-making processes — operator-specific free text]

4.1 Processors and recipients

Table scrolls horizontally on narrow viewports

Name	Activity	Location	Joint controller	Processor	DPA
------	----------	----------	------------------	-----------	-----

Counselling centres or organisations	Professional counselling	Germany	Yes	No	No
--------------------------------------	--------------------------	---------	-----	----	----

neusta integrate GmbH	Server hosting, production operation	Germany	No	Yes	Yes
-----------------------	--------------------------------------	---------	----	-----	-----

GS Design GmbH Kreuzbergstr. 30 VH, 10965 Berlin	Development, maintenance, support	Germany	No	Yes	Yes
--	-----------------------------------	---------	----	-----	-----

Greyt.IT UG Richardstr. 11, 12043 Berlin	subcontractor of GS Design GmbH	Technical development	Germany	No	Yes	Yes
--	---------------------------------	-----------------------	---------	----	-----	-----

Development workstations have no access to personal production data; development and testing use only synthetic data. Production operation and administration are handled by the operating service provider in the data centre (Annex 3 to the data processing agreement, dated 14 August 2026).

4.2 Roles and permissions

The platform has four staff levels and the anonymous advice seeker. Internally, fourteen Keycloak realm roles represent fine-grained API permissions. Two rules apply throughout: hierarchical isolation — one organisation cannot see another, and one counselling centre cannot see another centre's advice seekers or counsellors — and inheritance of legal texts: legal notice, privacy notice and consent text exist at every level; where no local version exists, the version from the parent level applies.

Platform administrator

Operates the platform, creates organisations and maintains legal-text templates at platform level. Technically cannot access chat content.

user-admin — 2FA mandatory

Organisation administrator

Responsible for an organisation: creates counselling centres and their administration, maintains legal texts at organisation level. Fully isolated from other organisations.

tenant-admin — single-tenant-admin — 2FA mandatory

Counselling-centre administrator

Manages a counselling centre: invites counsellors, configures the live-chat link, topics and postcode assignment, and can override their centre's legal texts.

agency-admin — restricted-agency-admin — restricted-consultant-admin

Counsellor

Accepts enquiries from the waiting room (oldest first) and provides encrypted counselling.

Supervision is a function of this role, not a separate role.

consultant — group-chat-consultant — supervisor-consultant

Advice seeker (anonymous) — enters the waiting room without registration under a system-generated pseudonym; Keycloak role anonymous. Only the pseudonym, short-lived session cookie, queue position and topic selected through the link are collected. On leaving, the pseudonym and room are automatically removed. The user role is reserved for a future registered workflow.

4.3 Permission matrix

Table scrolls horizontally on narrow viewports

	Capability	Platform administrator	Organisation administrator	Centre administrator	Counsellor	Advice seeker
--	------------	------------------------	----------------------------	----------------------	------------	---------------

Create organisations	Yes	No	No	No	No	No
----------------------	-----	----	----	----	----	----

Create counselling centres	No	Yes	No	No	No	No
----------------------------	----	-----	----	----	----	----

Create / invite counsellors	Yes	Yes	Yes	No	No	No
-----------------------------	-----	-----	-----	----	----	----

View own organisation's data	n/a	Yes	own centre only	own centre only	No	No
------------------------------	-----	-----	-----------------	-----------------	----	----

View other organisations' data	No	No	No	No	No	No
--------------------------------	----	----	----	----	----	----

Edit platform-level legal texts	Yes	No	No	No	No	No
---------------------------------	-----	----	----	----	----	----

Edit organisation-level legal texts	No	Yes	No	No	No	No
-------------------------------------	----	-----	----	----	----	----

Edit centre-level legal texts	No	Yes	Yes	No	No	No
-------------------------------	----	-----	-----	----	----	----

Generate live-chat links	No	Yes	Yes	No	No	No
--------------------------	----	-----	-----	----	----	----

Accept a waiting-room ticket	No	No	No	Yes	No	No
------------------------------	----	----	----	-----	----	----

Toggle own live-chat availability	No	No	No	Yes	No	No
-----------------------------------	----	----	----	-----	----	----

Read chat content	E2EE	E2EE	E2EE	own session only	own session only	own session only
-------------------	------	------	------	------------------	------------------	------------------

Deletion on leaving	No	No	No	No	Yes	No
---------------------	----	----	----	----	-----	----

2FA enforced	Yes	Yes	recommended	recommended	n/a	n/a
--------------	-----	-----	-------------	-------------	-----	-----

4.4 Inheritance of legal texts

Platform template — platform administrator

Organisation version — organisation administrator

Counselling-centre version — centre administrator

Effective text for advice seekers

Legal notice, privacy notice and consent text exist at every level. If a counselling centre does not maintain its own version, the organisation's version applies; if the organisation has none, the platform template applies. Advice seekers therefore always see a complete set of legal texts.

4.5 Governance and decision-making bodies

Organisational part — maintained by the platform operator (contractual documents) — editing in the administration area will follow —

This section describes the organisation, decision-making processes and legal balancing by the organisation. It cannot be derived from source code and is therefore not maintained by ORISO. Until the organisation writes it, the document contains only the draft text, originally collapsed; the square brackets deliberately mark open fields.

Show draft text

The platform is operated by [controller's name] together with [name of association or cooperation]; it serves affiliated organisations and their counselling centres. The central steering body is [body's name, e.g. steering committee], composed of [membership: numbers and appointing organisations], meeting [frequency, e.g. twice annually]; it decides on purposes and means of processing, fundamental matters and the budget. Operational management is assigned to [office/department], which reports to the body at least [frequency]. The body receives specialist advice from [other bodies, e.g. data protection advisory board, technical development steering group], whose responsibilities and membership are set out in [reference to cooperation agreement/rules of procedure]. Organisations and counselling centres are legally independent bodies; they participate in decision-making through [appointment or participation procedure].

Chapter 5

Responsibility

Organisational part — maintained by the platform operator (contract documents) — editing in the administration area to follow

This section describes the organisation, decision-making processes and legal balancing by the affiliated organisation. It cannot be derived from source code and is therefore not maintained by ORISO. Until the organisation prepares it, the document contains only draft text; square brackets deliberately mark unresolved fields.

Show draft text

The controller within the meaning of § 4 No. 9 KDG / Art. 4(7) GDPR is [name, legal form, address]. Processing occurs under joint controllership pursuant to § 28(1) KDG / Art. 26 GDPR with [list: affiliated organisations, cooperation partners]; an arrangement pursuant to § 28(1) sentence 2 KDG / Art. 26(1) sentence 2 GDPR has existed since [date] and allocates obligations in annexes [numbers], particularly data subject rights and information duties. Affiliated organisations remain responsible for professional counselling, including case documentation outside the platform. Processors pursuant to § 29 KDG / Art. 28 GDPR include [hosting operator] for operation and hosting of the production environment and [development/support provider] for development, maintenance and support; processing agreements exist with both, and processing takes place in [country]. [Name, organisation, contact] performs the data protection officer function; [name and address of supervisory authority] is competent.

Chapter 6

Procedures and technology

E2EE Olm / Megolm — TLS transport encryption — 2FA for counsellors — anonymous accounts deleted on a timer

Technical part — maintained by ORISO —

6.1 Purpose

Processing aims to provide and technically operate an online counselling platform ("platform") through which organisations and counselling centres can fulfil their professional counselling mandate digitally, independently of location and with accessible entry. The organisations are responsible for counselling itself and its specialist documentation; substantive case documentation does not take place on the platform. Counselling content is transmitted and stored with end-to-end encryption (Section 6.9).

6.2 Counselling formats

6.2.1 Individual counselling (1:1 chat)

Registered advice seekers send their initial enquiry to a counselling centre; assignment follows the postcode provided and the selected counselling topic. Counselling takes place in a separate, non-publicly discoverable, end-to-end encrypted chat room, synchronously or asynchronously. Another counsellor may access an existing case only through the logged handover procedure (Section 6.13).

6.2.2 Anonymous individual live chat

Individual live chat is usable without registration. The advice seeker enters a virtual waiting room under a system-generated pseudonym; no personal details are collected. This chat also uses end-to-end encryption. Anonymous accounts are automatically deactivated following inactivity and subsequently deleted (Section 6.18).

6.2.3 Group chat

Group chat enables moderated many-to-many counselling, particularly for self-help formats. Moderators create offers with a topic, date, time and a one-off or recurring schedule; expired group chats are automatically deactivated. Group rooms are also created with end-to-end encryption enabled.

Risk and compensation. Group participants perceive one another; confidentiality towards other advice seekers therefore depends on pseudonymity and moderation, rather than technical separation. Compensating safeguards are system-generated pseudonyms (Section 6.3), moderation permissions including removing participants, and participant limits. A recurring series can itself reveal a participation profile; moderation and participant information must address this residual risk.

6.2.4 Video and audio counselling

Video counselling is browser-based through a self-operated media relay, described separately in Section 6.10.

6.2.5 Voice messages

Voice messages are available in every chat format and can be disabled by organisation and chat type; their specific risk profile is described separately in Section 6.11.

6.2.6 Appointment management not delivered

Appointment management in the sense of a calendar or booking module is not part of the current service scope. A model is described in an architectural decision (ADR-020, “Scheduled calls, secure invitations, and a unified contact calendar”, status “Accepted”); none of it has yet been delivered. An appointment record in the data model originates from the predecessor platform and is not enabled in the delivered version. This DPIA therefore does not assess the planned function; it must be added upon delivery.

6.3 Advice-seeker registration, anonymity and pseudonymity

Registration is possible without identifying information. The username is system-generated (combining an adjective, animal name and name component, supplemented with an avatar colour); a freely chosen, potentially identifying real name is excluded by design. This is a deliberate improvement over the predecessor platform, which allowed freely chosen usernames. The postcode is mandatory to assign the responsible counselling centre; its accuracy is not checked. An email address is optional.

Honest classification. A system-generated pseudonym is not anonymous data. The account identifier permanently links it to all counselling interactions of the same person, so it must be treated as personal data. Complete anonymity exists only in registration-free individual live chat, while the advice seeker does not voluntarily provide identifying details. Whether use is anonymous thus follows the access route and account status — it cannot be inferred from the displayed name.

Effective but limited data minimisation. Depending on the specialist area, details stored alongside a session form a narrow quasi-identifier set: postcode, age, gender, reason for counselling and relationship situation occur together in one row. A re-identification risk therefore cannot be ruled out for small centres. Compensating safeguards are voluntary additional details, specialist-area control of collection scope and absence of links to external data sources. A registration origin reference (referrer) is also stored; it is unnecessary for counselling and must be identified as a minimisation candidate.

6.4 Counsellor and administrative accounts and invitation procedure

Counsellor and administrative accounts are created through invitations by the relevant organisation or centre administration, rather than by data subjects themselves. First and last name, work email address, target role and organisation/centre assignment are processed. Invitations arrive by email with a time-limited, cryptographically secured link; the access key is stored only as a hash.

Counsellors use real names; their chat-service display name corresponds to their real name, while advice seekers appear only under pseudonyms. Bulk importing invitees from a file is possible; these data are not collected from data subjects themselves, so the inviting organisation must fulfil the information obligation for third-party collection under Section 16 KDG / Article 14 GDPR.

Residual risk. Sending is archived with a complete copy of the message, including recipient address; no retention period has yet been defined. No deletion run exists for expired, unaccepted invitations either. Both are listed as deletion-concept measures (Section 6.18).

6.5 Authentication, roles and two-factor authentication

Login uses central identity management (Keycloak), OAuth 2.0 and OpenID Connect with signed tokens; passwords are stored only as salted hashes in identity management and are never available to the application in plaintext. All connections use transport encryption.

Role model. The platform has four staff levels and the advice seeker; internally, fine-grained realm roles represent API permissions.

| Level | Task | Access to counselling content

| Platform administration | Platform operation, creation of organisations, maintenance of platform-level legal-text templates | no

| Organisation administration | Responsibility for an organisation: creation of counselling centres and their administration, maintenance of organisation-level legal texts | no

| Counselling-centre administration | Centre management: inviting counsellors, configuring topics, postcode areas and live-chat access | no

| Counsellors | Accepting enquiries and conducting encrypted counselling; supervision is a function of this role, not a separate role | own cases only

| Advice seekers | Using counselling | own session only

Two rules apply throughout: hierarchical isolation — one organisation cannot see another, and one centre cannot see another centre's advice seekers or counsellors — and inheritance of legal texts: legal notice, privacy notice and consent text exist at each level; absent a local version, the parent-level version applies.

Composite administrative roles. Creating an organisation administrator assigns several roles as a bundle (user, agency and tenant management, and topic management outside single-domain operation). Platform administration technically uses the same combination without tenant binding; it therefore has comprehensive read permissions across organisations. No role currently permits operating an organisation without access to its confidential operational and counselling metadata. Section 6.16 addresses this residual risk.

Two-factor authentication. Second-factor options are an authenticator application (TOTP, six-digit code, 30-second interval) and an email one-time code (six digits, valid for 15 minutes, at most three failed attempts). Setup is optional for advice seekers. For all invited accounts — particularly organisation/centre administrators and counsellors — setup is a mandatory part of account activation: accounts remain blocked until a second factor is active. Exemption is possible only administratively, requires a reason and is documented per person with timestamp and initiating person. Platform administrators, by contrast, only receive a login prompt that can be deferred per session ("set up later") and reappears at the next login; no technical enforcement exists there.

Honest statement of limits. The relevant identity-management configuration is imported at first startup and subsequently modified by runtime scripts; no source-versioned configuration file is therefore authoritative for live state. A live-realm export is needed for this DPIA's final version. Versioned states also show that automatic protection against systematic login guessing (brute-force blocking) is not enabled — meaning no failed-attempt or IP history is stored — and access-token validity is generously set to five hours. A password policy (minimum length, character classes) is not evidenced by the repositories and must not be claimed in this DPIA before live-system verification.

6.6 IP-address processing and logging in transit

Application services do not store data subjects' IP addresses in specialist datasets; they use pseudonymous identifiers and signed tokens. A filter for forwarding client IPs to specialist services has a strict mode removing the forwarding header; this strict mode is not active by default.

It must honestly be stated that IP addresses arise elsewhere in transit:

The upstream ingress proxy logs the client IP, requested path and browser identifier in its standard format. Central log shipping is not configured; retention follows container-platform rotation settings and is therefore not explicitly defined.

Identity management does not persist login events in its database but writes them through its active logging listener to the server log stream, including IP addresses. An IP-free listener variant exists but is inactive — an obvious, low-effort hardening measure.

Individual two-factor extension endpoints include usernames in URL paths, placing them in upstream access logs.

Video connection setup currently contacts public STUN servers of a US provider, transferring client IPs to a third-country recipient (Section 6.10).

Compensation and measures. The administration-interface container already deliberately logs without client IPs; the same format is planned for other web containers. Measures are enabling the IP-free identity-management listener, defining explicit access-log retention, masking token-bearing URL parameters in access logs and replacing external STUN servers with self-operated components. The predecessor documentation's statement that IP addresses were "never recorded by the system" is unsustainable in this absolute form and deliberately not carried forward.

6.7 Cookies and website usage data

The platform completely avoids tracking, analytics services, advertising networks, external fonts and third-party scripts; it serves all components itself. No product or error telemetry is collected for third parties in users' browsers. Only technically necessary cookies are used; a consent banner is therefore unnecessary. The application cannot be used without cookie support; users are informed before login.

| Cookie | Setter | Purpose | Storage period | Attributes

| keycloak | Application | API authentication (access token) | session | SameSite=Strict, Secure

| refreshToken | Application | Renewing login session | session | SameSite=Strict, Secure

| CSRF-TOKEN | Application | Cross-site request forgery protection | session | SameSite=Strict

| lang | Application | Language selection | session | SameSite=Strict

| useInformal | Application | Informal/formal address | session | SameSite=Strict

| tenantId | Application | Tenant assignment | session | SameSite=Strict

| ui-version | Application | Interface-version selection | limited (expiry date) | SameSite=Lax

| matrix_sso_user_id, matrix_sso_access_token, matrix_sso_device_id, matrix_sso_hs_url | Application | Chat-session handover when changing interface version | session | SameSite=Lax, Secure

| oriso-admin.language | Administration interface | Language selection | limited | —

| AUTH_SESSION_ID, KEYCLOAK_IDENTITY, KEYCLOAK_SESSION, KC_RESTART, KEYCLOAK_LOCALE, KC_AUTH_STATE (each optionally _LEGACY) | Identity management | Single-sign-on session | tied to realm session lifetimes | HttpOnly, Secure

Residual risk. The application's two authentication cookies lack HttpOnly and are also mirrored in browser local storage, making them readable to page-context scripts. Chat-session handover cookies additionally carry a Matrix access token with relaxed SameSite. Both increase the impact of successful cross-site scripting and must be identified as hardening measures (HttpOnly, server-side session management, avoiding mirroring). No Content Security Policy or Referrer Policy is currently set at the ingress proxy.

6.8 Use on different devices

Specialist processing takes place on the server; devices retain session data, display settings and, by design, cryptographic end-to-end encryption keys. Securing devices is users' responsibility; counsellors additionally follow their organisation's rules for work or approved devices.

Specifically, devices store access and refresh tokens and their expiry times, chat-service credentials (access token, user and device identifiers), the end-to-end encryption cryptographic

store in a browser database (IndexedDB) and interface settings.

Two findings must be openly stated. First, unsent message drafts are stored in plaintext in browser local storage; end-to-end encryption starts only upon sending. This can disclose counselling content on shared devices. Second, logout clears local and session storage, but not the cryptographic store in the browser database; key material therefore remains on the device after logout. Both require measures (encrypting or avoiding persistent drafts; completely wiping the cryptographic store on logout). Until then, advice to use personally controlled, locked devices forms part of user information.

6.9 End-to-end encryption and key concept

The platform is based on the open Matrix communication protocol with a self-operated homeserver. All counselling rooms — individual counselling, anonymous live chat, group chat, supervision and internal case coordination — are mandatorily created server-side with end-to-end encryption enabled; no unencrypted sending path exists.

Key concept.

Device keys and Olm. Each device generates its own key pair at first login. Direct device-to-device exchange, particularly distributing room keys, uses pairwise Olm encryption.

Room keys and Megolm. Message content is encrypted with a room key using Megolm (m.megolm.v1.aes-sha2). The key is distributed exclusively to authorised devices of room members; the server never receives it. Encryption is a room property rather than an interface switch — downgrading individual messages is excluded by design.

Device verification (cross-signing). Keys are generally distributed only to cross-signed, verified devices. Anonymous live-chat users' devices are exempt, prioritising counselling accessibility over device isolation; encryption itself remains fully effective.

File attachments. Files are additionally encrypted client-side with a one-time AES-256 key before leaving the device. The server receives neither filename nor content type, only an undecryptable block; the associated key travels exclusively within the Megolm-encrypted message.

Server-side key backup ("Silent Key Backup"). Recovery after device loss or new login uses a server-side, itself encrypted backup of all room keys. Its key resides in encrypted Secret Storage, openable only with a recovery key retained by the user. The server cannot read backed-up keys. Resetting the backup is destructive: previously backed-up history becomes permanently unreadable.

Parked device (Device Dehydration). An additional deposited pseudo-device for seamless resumption is implemented but feature-gated and effective only when enabled. It expands the attack surface by a server-parked identity and requires separate assessment upon activation.

Key transfer during case handover. Relevant room keys are selectively and securely transferred to a newly joining authorised professional's device to share counselling history (Section 6.13).

No federation. Federation with external Matrix servers is deliberately disabled; no counselling data leave the platform homeserver for external servers.

Honest distinction — what is assured and what is not. The assurance is that counselling content reaches and leaves the server only encrypted and that operators and service providers cannot view plaintext. A cryptographic exclusion of every conceivable operator action is not assured: the homeserver has administrative functions capable of issuing session tokens for user accounts; access obtained this way could receive future keys. Within a counselling centre, the decisive confidentiality boundary is also not encryption but application access control combined with the logged handover procedure (ADR-002, Section 6.13). This distinction is deliberately disclosed because a blanket encryption promise would misdescribe actual protection. Administrative homeserver access must be contractually constrained and logged as a supporting organisational measure.

Improvement over the predecessor platform. There, end-to-end encryption was feature-switch-controlled alongside a server-side encryption path whose key components all resided on the server; the operator could technically decrypt content. Anonymous live chat was practically exempt from end-to-end encryption because keys were derived from login passwords. Participants without their own public key also had a fallback whose replacement key could be derived from a server-known identifier, and errors silently fell back to server-side encryption. The current platform has neither a server-side decryption path nor fallback; encryption applies throughout every chat format, including anonymous live chat, files and voice messages.

Metadata remaining by design. Even with effective end-to-end encryption, the homeserver processes metadata: room associations and memberships, pseudonymous sender identifiers, timestamps, event types, referenced events for replies and reactions, ciphertext size, read receipts and online status (presence). Online status is currently not disabled; disabling it should be considered for a counselling platform. Reactions and relationships between events remain visible server-side; this is inherent in the protocol for reaction events.

6.10 Video and audio counselling

Browser-based video and audio counselling uses a self-operated media relay (LiveKit) and Element Call. Call rooms are not publicly joinable; only members of the associated counselling room gain access. Participants' media streams use end-to-end encryption; if encryption is unavailable, the call is not established (fail-closed). Recording is not configured; no recording or export service is part of delivery. Empty rooms are automatically discarded after a short period. The delivered call-application configuration contains no product, crash or error telemetry to third parties.

Residual risk. Connection setup currently contacts public STUN servers of a US provider, transferring client IP addresses to a third-country recipient. Switching to self-operated STUN/TURN components is necessary; until then, the privacy notice must disclose the transfer.

Improvement over the predecessor platform. Media encryption there worked only under narrow conditions (certain browser families, support by all participants) and was automatically disabled when additional people entered the waiting room; the media relay generally saw content.

6.11 Voice messages

The platform supports short voice messages (at most three minutes) in every counselling chat format. Organisation and chat-type settings — individual counselling, anonymous live chat, groups, supervision — can disable the function in administration; it is enabled by default and also depends on media-upload permission. Individual centre-level disabling is not currently supported.

Specific risk. The human voice is identifying and close to biometric information. In pseudonymous counselling, a voice message weakens the advice seeker's pseudonymity towards the counsellor, though not towards platform or server operators. Advice seekers voluntarily and actively disclose their voice through deliberate recording with preview and discard options; no covert collection occurs.

Safeguards. Voice messages are transmitted solely with end-to-end encryption: audio is encrypted client-side with a one-time AES-256 key before leaving the device; the key travels exclusively within the Megolm-encrypted chat message. The server stores only undecryptable ciphertext without filename or content type; recording duration and time also reside solely in encrypted message content. Operators and service providers cannot listen to or substantively evaluate voice messages. Audio is not permanently stored on devices. Server metadata remaining by design are room assignment, pseudonymous sender identifier, timestamp and ciphertext size — size allows a rough estimate of recording duration.

Residual risk and planned measures. Encrypted media files currently have unlimited server retention; automatic media retention and switching to authenticated downloads are planned hardening measures.

6.12 Media uploads and malware scanning

The platform permits image uploads in chats, including anonymous registration-free live chat, and in legal-text editorial editors. Editorial images undergo server-side format validation (file signature checks, PNG/JPEG/WebP allowed, no SVG, 2 MB limit, authenticated upload).

Chat media currently have no automated virus or content scan. As an interim risk reduction, anonymous guests' live-chat images initially appear blurred to counsellors and are displayed only after deliberate individual approval; senders cannot manipulate a blocking flag. This check is enforced client-side; the file itself remains retrievable server-side. Outside anonymous live chat, there is no display pre-check.

The target architecture is defined in an architectural decision ("Media scanning via matrix-content-scanner, fail-closed"): an upstream scanning proxy with virus scanning and optional AI image assessment that makes unchecked or rejected files inaccessible server-side. A reviewed proof of concept, disabled by default, exists but is not deployed in production; commissioning was deferred in July 2026 for prioritisation reasons. No activation date is set. Because end-to-end encryption has become permanently active since the architectural decision, operating the proxy additionally requires implementing the encrypted-media protocol. Before activating AI image assessment, a processing or subprocess agreement assuring non-retention is required; virus-only scanning can be enabled independently. Planned bot protection at anonymous live-chat entry is likewise not operating.

Residual risk. Malware or unlawful images can technically be transmitted and retrieved; blur/approval mechanisms and format validation only partly limit exposure. Media downloads on the homeserver are currently possible without authentication: anyone knowing a media address can retrieve the encrypted block. File encryption protects substance, but this cannot support an assurance of "authorised access only" and is therefore listed as a hardening measure.

6.13 Collegial case coordination (team discussion) and case handover

(1) Team discussion. Counsellors at the responsible centre have a separate technical discussion room to coordinate an enquiry not yet accepted (ADR-016). This is a separate Matrix room; the advice seeker is never a member and cannot view or discover it. Participation permissions match enquiry visibility: only counsellors actively assigned to the case's centre; application access by other centres, the organisation or platform operator is not provided (server-enforced). On acceptance, the room automatically closes permanently and remains read-only for centre counsellors (technically enforced through Matrix permission levels). Room creation and counsellor participation are timestamp-logged; message content is not logged. Advice seekers have no consent or objection right for team discussion; processing is not based on consent but designed as internal professional coordination without disclosing counselling content to additional recipient groups.

Honest statement of limits. Team discussion concerns an advice seeker without their knowledge; the archive remains permanently readable. It creates a dataset about the person outside their counselling room, relevant to access rights (Section 8.4). Planned retention is 90 days from archiving, at the latest until deletion of the associated counselling session. Deletion is decided but not implemented (as at 5 September 2026); no archive deletion path exists in delivery. The period is planned as an operator-configurable parameter without code changes. Reason: the archive's purpose — contextual continuity for a newly taking-over professional — is largely fulfilled when the case is accepted; subsequently it contains only process narrative about the advice seeker, whose indefinite retention cannot be justified against storage limitation (Section 7(1)(e) KDG; Caritas specialist position: process data are deleted after the client relationship ends). The period is a convention, not a statutory value, and remains subject to approval by the operational data protection officer. Currently only creation and participation are logged, not read or archive access.

(2) Case handover. Additional counsellor access to an existing case — sickness cover, holiday cover, collegial advice or departure — occurs solely through structured handover. Only counsellors of the same centre may apply. Every request requires a catalogued reason and justification. Each reason defines whether prior advice-seeker consent is required. Where required, the request remains pending; the advice seeker accepts or refuses within the application, and access is granted or refused only afterwards. Where consent is unnecessary — standard cases of sickness, holiday, emergency and departure — a system message immediately informs the advice seeker of the takeover and reason. The previous professional remains a room member, allowing transfer back.

(3) Logging. Every handover request, including refusals, is stored for auditability (requesting and previous professional, reason, outcome, consent requirement, applicable policy, timestamps). Counselling content is not part of log data. Log access is role-limited and precisely filtered by tenant and centre; administrator accounts without centre assignment receive no log access (fail-closed).

Residual risk. Mandatory free-text justification is stored and displayed to administration; it may contain case content. Until masking exists, the claim “without content” is accurate only with this qualification. Planned measures are an input warning (“no case content in the justification”) and masking in administrative logs. One catalogued reason (“professional ill”) also constitutes health data about the counsellor and requires employment-data-protection assessment.

(4) Technical confidentiality. Both room types are created server-side as private, undiscoverable Matrix rooms with end-to-end encryption enabled. The decisive confidentiality boundary towards non-assigned counsellors of the same centre is application access control (visibility and permissions, centre-specific search) together with the logged handover procedure, rather than encryption; third parties outside the centre additionally face room-membership separation.

(5) Configurability. Platform administration can enable or disable team discussion per tenant (organisation); a deployment-wide switch also exists. The handover reason catalogue, including consent requirements per reason, is administratively configurable but currently platform-wide, rather than per organisation. Neither function has a complete delegation cascade down to individual centres; this must not be claimed.

(6) Supervision — distinction. Supervision is a separate third tool providing accompanying read access. Standing supervision is permanently active and cannot be disabled by the advice seeker (decision dated 5 September 2026, ADR-008 addendum): it forms part of the centre’s professional working method; the supervising person belongs to the same centre, only reads, does not write to the counselling room and is invisible to the advice seeker. Active information replaces an objection procedure: centre privacy notices inform advice seekers when entering chat, and an additional system message should appear in their counselling room once a counsellor accepts the enquiry, when standing supervision is attached. This message is decided but not yet implemented (as at 5 September 2026; ORISO-Frontend#1315). A technically existing opt-out endpoint is not offered in the application; removal remains open. Case handover retains its own objection procedure unaffected. Supervision records may include free-text notes containing special categories of personal data about advice seekers (Section 11 KDG, Article 9 GDPR). Planned retention is case end + 90 days (start: session completion or archiving, alternatively termination of the supervision relationship, whichever occurs first). Deletion is decided but not implemented (as at 5 September 2026); today deleting a session or counsellor removes only the database row, while the Matrix side room remains indefinitely. The period is planned as an operator-configurable parameter without code changes. Reason: professional oversight ceases at case end; only process narrative about the advice seeker remains, which the Caritas specialist position says should be deleted “after the client relationship ends”. The period is a convention, not a statutory value, and subject to approval by the operational data protection officer.

(7) Reason catalogue and special categories — current delivery and decisions. The delivered catalogue contains COUNSELLOR_ASKED_FOR_ADVICE, COUNSELLOR_ON_HOLIDAY, OTHER_EMERGENCY, COUNSELLOR_IS_ILL and COUNSELLOR_LEFT. “Professional ill” (COUNSELLOR_IS_ILL) is health data about the counsellor under Section 11 KDG / Article 9 GDPR; it is written to the handover record, administrative log, notification parameters and, as derived display text, the advice seeker’s counselling room. On 5 September 2026 a decision replaced the catalogue with cause-neutral reasons PLANNED_ABSENCE,

UNPLANNED_ABSENCE, ASSIGNMENT_ENDED and ADVICE_REQUESTED, with advice-seeker text naming neither cause nor duration (addendum to ADR-002-silent-room-membership-and-access-control-curtain.md). The opposite handover direction (“hand off case”: offer, recipient acceptance, then the same approval path) is also decided but not delivered; acceptance is expressly not a third consent threshold under ADR-022. Neither exists in delivery and neither may be described as current until implemented; already-sent room events are immutable and cannot retrospectively be made cause-neutral.

(8) Evidence chain. Function description: Case Handover. Architectural decisions (cited by filename, not number): ADR-002-silent-room-membership-and-access-control-curtain.md — silent room membership, access-control curtain, addendum dated 5 September 2026; ADR-016-team-besprechung-side-room-hard-close-at-accept.md — hard closure of discussion room; ADR-022-consent-gates-and-re-consent-in-counselling-sessions.md — exactly two consent thresholds. Code: endpoints, consent requirement by reason, tenant/centre-specific log visibility, delivered reason catalogue. Machine-readable evidence is recorded under case-handover-* identifiers in evidence-map.yaml.

Open issue. Handover logs have no retention period: service configuration defines periods for notifications (90 days after reading, 365 days absolute) and break-glass logs (12 months), but not case_handover_request. Deletion occurs only upon deletion of the counsellor’s account. Planned retention is 12 months from log-entry creation, with daily deletion. Deletion is decided but not implemented (as at 5 September 2026). The value is planned as an operator-configurable parameter without code changes. Reason: the log contains no conversation content and serves only to verify who gained case access, when and why; it does not fall below the binding six-month minimum (Section 6(f), sentence 2 KDG-DVO, input control) and follows the delivered break-glass audit’s twelve months. The deletion concept (Annex 2) must finally define the period; this is a controller decision, not a technical derivation, subject to approval by the operational data protection officer.

6.14 In-app and email notifications

In-app notifications (“timeline”). Each notification event produces a tenant-separated server record: recipient pseudonym, event type, creation/read timestamp, session reference, internal application link, display texts and structured metadata.

Counselling communication content is not stored: encrypted-chat message texts never reach notification processing by design because encrypted events have no message body; configurable preview mode is fixed to “no preview” in all environments, so client-submitted preview texts are also discarded.

However, communication metadata are stored: who wrote to whom, when and in which session, message content type, counsellor display names and, for new enquiries, counselling-topic category, itself capable of revealing the counselling reason. Handover notifications currently additionally include counsellor-written free-text justification, potentially revealing counselling content. Each notification’s read timestamp is stored to the second, enabling usage and presence profiles.

Access is strictly limited to the recipient; the API provides no administrative read access. Data subjects can fully delete their notification history themselves at any time. Since delivery dated 14 August 2026, two standard periods apply: read notifications are deleted 90 days after reading and all others at most 365 days after creation; a nightly deletion run (03:15) enforces both, with both values environment-configurable (EVENT_NOTIFICATION_RETENTION_READ_DAYS, EVENT_NOTIFICATION_RETENTION_ABSOLUTE_DAYS; 0 disables the respective period). Account deletion has since included the records, with separate deletion steps for advice seekers and counsellors.

Reservation. Both periods are this DPIA’s proposal and are not yet confirmed by the controller’s data protection officer; service configuration comments also state this.

Planned remedies: (1) finish migration to entirely client-rendered notification texts, eliminating server-side plaintext display texts, including handover free text; (2) reduce read timestamps to a read flag; (3) remove preview mode from source code so a configuration change alone cannot turn the table into a content store.

Email notifications. Email leaves the end-to-end encryption domain. Invitations, password resets, two-factor one-time codes, new-enquiry notices and contract-signing notifications are sent. Chat or counselling content is not included; absence of message texts has been verified in the source baseline. Depending on occasion, emails do contain enquiry postcode, centre name, counsellor name and sometimes advice-seeker pseudonym. Delivery itself reveals the existence of a counselling relationship to mail infrastructure. Several sending routes (application services, tenant mail servers, counselling-type service) use mandatory transport encryption (STARTTLS).

Residual risk. Mail-server credentials are protected inconsistently: encrypted in one location, encrypted in another only when a secret is configured, and unencrypted in a third configuration record. Standardisation (encryption at rest, write-only API access) is necessary (also Section 6.16). Mobile push notifications through a US service are disabled in delivery; they contain no content by design but would transfer metadata to a third country and require separate assessment before activation.

6.15 Statistical evaluation

Statistics are exclusively aggregated and detached from individual counselling cases. An administration dashboard displays aggregate figures (new enquiries, active cases, topic distribution, counsellor numbers and group chats — per organisation or centre, daily, weekly and monthly); individuals cannot be inferred. Small-cell suppression protects against inference from small groups: aggregates appear only with at least five contributing counsellors, otherwise values are suppressed; checks are fail-closed and enforced in production.

Counsellor message statistics store no plain identifier: counting uses a cryptographic pseudonym (HMAC-SHA256 over the counsellor identifier with a server-managed secret). Counsellors can see only their own metrics; the application offers no third-party individual performance evaluation.

Honest statement of limits. Pseudonymisation is not fully effective: the triggering counselling-session identifier is also stored in plaintext, permitting re-identification through session-data linkage. These counts have no retention period and are not removed on counsellor-account deletion. An individual-session endpoint, including postcode, is reserved for technical service accounts. The application can also publish statistical events to a message bus; registration events would contain account identifier, age, gender, postcode, topic and referrer in one record. Publication is disabled in delivery; no processing recipient was found in reviewed sources, and message-bus transport encryption is not configured. Before activation, recipients, storage location, retention and deletion propagation must be clarified and event content minimised.

6.16 Tenant isolation

The platform supports multiple tenants: each organisation forms a tenant with associated centres, counsellors, legal texts and configuration. Isolation uses tenant identifiers on records and an application filter; it is application-level, not database-level. Specialist datasets such as handover logs and notifications carry and filter tenant identifiers; administrative evaluations are restricted to the caller's agencies and fail closed.

Risk and compensation. Purely application-level separation is sensitive to misconfiguration and programming errors; a cross-organisation visibility error occurred and was fixed previously. Consistent filtering at access layers, fail-closed administrative evaluations and a restricted agency-administrator role compensate. Regression tests for tenant isolation and assessment of database-level separation must be listed as measures.

Finding requiring open disclosure. Platform administration can retrieve every tenant's complete settings, currently including organisation mail-server credentials in plaintext, also stored unencrypted; DPA signature data are likewise visible across organisations. Required measures are write-only secret API access, encryption at rest and separation of operational and viewing permissions (break-glass access with organisation approval, time limit and logging). Until implementation, platform-administrator membership must be narrow, contractually constrained and documented.

6.17 Operation, observability and telemetry

Service logging. Application services write structured logs to standard output; services do not rotate or retain logs themselves, leaving this to the container platform. Log context contains a correlation identifier rather than account identifier. Nevertheless, personal details appear in some log texts: account identifiers, plaintext usernames, occasionally complete email addresses and, at debugging level, access-token content. Log level can be changed at runtime through an exposed management endpoint. Measures: secure that endpoint, remove record dumps containing names/email addresses, filter personal details and define explicit log retention.

Tracing and metrics. Integration with an observability platform (SigNoz) is prepared; export is disabled by default and in production in delivery. The pre-production environment exports only metrics, not traces. Before activation, traces must be assessed for identifier-bearing paths; observability retention and access protection must be defined.

Browser error reports. The application can report browser errors to the server (message text, requested address, browser identifier, call stack, correlation identifier, each length-limited). These may contain personal data and are subject to log retention. Browser data are not transferred to external telemetry services.

Backup and recovery. Chat-service database backup/recovery procedures retain full backups for 30 days and continuous log backups for seven days. Other core databases have no backup jobs in delivery — an availability gap under processing security, Section 26 KDG / Article 32 GDPR. More importantly, backup scripts include a path transferring database extracts to an external source-code management system of a US provider. Whether this path is active must be conclusively clarified before DPIA approval; if active, it constitutes an impermissible third-country transfer with practically undeletable history. Deleted data also survive in backups until backup periods expire.

Legal-text translation. An external language-model interface can translate tenant-specific legal texts (legal notice, privacy notice, DPA). The full text is transferred, including controllers' and data protection officers' names, addresses and email addresses. Providers are located outside the territorial scope; use requires a processing agreement and third-country-transfer assessment. Counselling content is never transferred to language-model services.

Operational chat-service hardening. Delivery enables open registration without verification, practically removes rate limits, permits unauthenticated media retrieval and defines no message or media retention. These contradict the principle that accounts originate exclusively through the application and must be resolved before production operation.

6.18 Deletion and retention

The deletion concept (Annex 2) consolidates periods by data category. Technical procedures are:

Account deletion by the data subject. Advice seekers can delete their accounts. A 48-hour read-only protection window precedes automatic execution. In fixed order, deletion removes identity account, chat account (with explicit deletion marker and room cleanup), sessions and additional data, topic assignments, supervision assignments, handover requests, agency assignments, pseudonym-registry entry, mobile-device identifiers and finally the account record. Deletion can be suspended for three to at most twelve months, with a documented reason.

Anonymous accounts. Deactivation after 360 minutes of inactivity, deletion after 2,820 minutes (47 hours), each checked hourly.

Group chats. Expired group chats are checked and deactivated every minute.

Registered accounts without counselling. A 30-day deletion run is implemented but disabled in delivery; if it remains inactive, accounts with supplied email addresses persist indefinitely.

Evidentiary data. Rejected DPA signatures are deleted after a configured period; signed ones are retained for evidence. Support-access audit logs are automatically deleted after twelve months — the only explicitly documented retention period in the dataset.

Tombstone record. After final deletion, a reference record retains the complete former account identifier and neutral display marker to resolve references in surviving records. It has unlimited retention.

Honest gap disclosure — what deletion currently misses. Account deletion does not cover in-app notifications, server-stored message drafts, pseudonymised counsellor message statistics, the archive of invitation emails sent, inactivity-notification audit logs or a migration-era person/chat-room mapping table absent from the application data model and therefore invisible to every deletion procedure. None has a time-based retention limit. The chat service additionally lacks message/media retention and deleted data remain in backups until expiry. “Complete” deletion may be claimed only after these gaps close; until then they must appear as deletion-concept measures. This disclosure is deliberate: a DPIA describing incomplete deletion as complete would defeat its purpose.

6.19 Overview of data categories and recipients

Deletion periods per data category: see Annex 2 — deletion concept (in preparation). Recipients and processors: see Chapter 4.

Landscape table — horizontally scrollable in its own container

| Data subjects | Source | Data categories | Protection class

| Registered advice seekers | Self-reported during registration/use | - system-generated pseudonymous username; password hash - unverified postcode; optional specialist-area details (e.g. age, concern) - optional email address, 2FA features - end-to-end encrypted counselling content, files and voice messages - session and notification metadata | I–III depending on voluntary details

| Live-chat advice seekers, without registration | System-generated | - generated pseudonymous username - temporary session data; automatic deletion after a short period | I–III

| Counsellors | Invitation by organisation administrators | - name, work email address - counselling centre, role/team assignment, 2FA status - pseudonymised activity statistics (HMAC) | I

| Organisation representatives signing DPA, not app users | Self-reported during signing | - name, role, organisation, email address - signature status/time (evidence purpose, Section 29 KDG / Article 28 GDPR) | I

| Administrators | Created by operator or organisation | - name, email address, role, tenant/centre assignment | I

Chapter 7

Legal bases

Technical part — maintained by ORISO —

Processing relies on different authorisations for each processing step. The assignment below gives the provision of the Church Data Protection Act (“KDG”) and, in parentheses, its counterpart in the

General Data Protection Regulation (“GDPR”), allowing switching through the compliance preset.

7.1 Overview

| # | Processing step | KDG legal basis | GDPR counterpart

| 1 | Technical usage and operational data (session control, technically necessary cookies, access and error logs, operational security) | Section 6(1)(g) KDG | (Article 6(1)(f) GDPR)

| 2 | Advice seekers’ registration data (system-generated pseudonym, password hash, postcode) | Section 6(1)(b) KDG | (Article 6(1)(a) GDPR)

| 3 | Voluntary additional information (email address, age, gender, reason for counselling, two-factor features) | Section 6(1)(b) KDG | (Article 6(1)(a) GDPR)

| 4 | Counselling content including special categories of personal data | Section 6(1)(b) in conjunction with Section 11(1)(a) KDG | (Article 9(2)(a) GDPR)

| 5 | Anonymous live-chat use without any personal information | KDG scope does not apply | (GDPR scope does not apply)

| 6 | Counsellor and administrator data (account, roles, assignment, two-factor status) | Section 6(1)(g) and (f) KDG | (Article 6(1)(b) or (f) GDPR)

| 7 | Pseudonymised counsellor activity statistics | Section 6(1)(g) KDG | (Article 6(1)(f) GDPR)

| 8 | Internal case coordination and handover (team discussion, handover log, supervision) | Section 6(1)(g) KDG; additionally Section 6(1)(b) KDG for handover reasons requiring consent | (Article 6(1)(f) or (a) GDPR)

| 9 | Organisation representatives’ signature data for the data processing agreement | Section 6(1)(c) in conjunction with Section 29 KDG | (Article 6(1)(c) in conjunction with Article 28 GDPR)

| 10 | Log and evidentiary data (access, invitation and support logs) | Section 6(1)(c) and (g) KDG | (Article 6(1)(c) and (f) GDPR)

7.2 Advice seekers’ data

(1) Technical usage data. Platform operation requires session control, authentication, technically necessary cookies and operational and security logs. This processing is based on legitimate interests under Section 6(1)(g) KDG / Article 6(1)(f) GDPR. The interest is in providing a functioning, available counselling service protected against misuse. No overriding interests of data subjects requiring protection oppose this, because processing is limited to technical necessities, no tracking or analytics services are used, and application services do not retain IP addresses in their specialist datasets. A qualification is that IP addresses occur in access logs of the ingress proxy and identity management (Section 6.6); a retention period must be defined to maintain necessity.

(2) Registration data. Registration is voluntary; advice seekers decide for themselves whether to use the service. Processing the system-generated pseudonym, password hash and postcode relies on consent under Section 6(1)(b) KDG / Article 6(1)(a) GDPR, obtained and documented during registration. The postcode is the only mandatory field and is used solely to assign the responsible counselling centre; its accuracy is not checked.

(3) Voluntary additional information. Providing an email address, enabling two-factor authentication and specialist-area details (including age, gender, relationship situation and reason for seeking advice) are voluntary and also rely on consent under Section 6(1)(b) KDG / Article 6(1)(a) GDPR. Consent can be withdrawn at any time; Section 8.10 describes the consequences.

(4) Counselling content. Counselling content regularly contains special categories of personal data under Section 11 KDG / Article 9 GDPR. Processing relies on explicit consent under Section 6(1)(b) in conjunction with Section 11(1)(a) KDG / Article 9(2)(a) GDPR, obtained before counselling

begins. Additionally, the platform operator technically cannot read the content because it is transmitted and stored solely with end-to-end encryption (Section 6.9); end-to-end encryption is not a legal basis, but an essential technical safeguard under Section 26 KDG / Article 32 GDPR.

(5) Anonymous use. Registration-free individual live chat collects no personal data about the advice seeker unless they voluntarily provide identifying information. To this extent, the KDG (GDPR) scope does not apply; as soon as the advice seeker provides personal details during the conversation, the legal basis in paragraph 4 applies. Classification follows the access route and account status, rather than the displayed name.

7.3 Counsellor and administrative-role data

Processing counsellors' and administrative roles' account, role and assignment data relies on legitimate interests under Section 6(1)(g) KDG and the church interest under Section 6(1)(f) KDG in a unified, secure counselling platform jointly operated for all affiliated organisations. Consent is not the principal basis because using the platform forms part of professional or voluntary activity and is not voluntary in the data protection sense.

Preset note (the only substantive difference). The church interest under Section 6(1)(f) KDG has no GDPR counterpart. This section therefore requires rewording in the GDPR preset: processing there relies on Article 6(1)(b) GDPR (performance of the employment or service relationship, where the counsellor is employed by the controller) and otherwise Article 6(1)(f) GDPR; for employees, the national employment data protection provision must also be applied. All other sections in this chapter are preset-neutral and only change the statutory references.

Employment data protection. Two processing activities particularly concern employees and require separate assessment: first, pseudonymised message statistics generate a row for each message sent and therefore allow an activity profile; their design lets counsellors view only their own metrics and subjects aggregated evaluations to small-cell suppression (Section 6.15). Second, the handover reason "professional ill" constitutes a health datum about the counsellor and must additionally be assessed against Section 11 KDG / Article 9 GDPR. Both issues require coordination with the competent employee representative body.

7.4 Organisation representatives' data

Details collected about signatories to the data processing agreement (name, role, organisation, email address, signature status and timestamp) fulfil a legal obligation under Section 6(1)(c) in conjunction with Section 29 KDG / Article 6(1)(c) in conjunction with Article 28 GDPR. The data subjects are generally not users of the counselling application; they sign through personalised, time-limited links. They therefore form a separate group of data subjects with a distinct processing purpose. Completed signatures are retained as evidence; rejected signatures are deleted after a configured period.

7.5 Log and evidentiary data

Access, invitation, handover and support logs serve accountability under Section 7(1) KDG / Article 5(2) GDPR and processing security under Section 26 KDG / Article 32 GDPR. The legal basis is Section 6(1)(c) and (g) KDG / Article 6(1)(c) and (f) GDPR. As these data have independent retention purposes, they are excluded from data subjects' deletion requests and subject to a separate retention period to be defined in the deletion concept. Several log datasets currently lack such a period (Section 6.18); this is listed as a measure because indefinite retention without a defined purpose would contradict storage limitation under Section 7(1)(e) KDG / Article 5(1)(e) GDPR.

7.6 Legal bases not relied upon

The following are explicitly not relied upon: processing for advertising or marketing, profiling, individual automated decisions under Section 24 KDG / Article 22 GDPR, and any sharing of counselling content with third parties for the operator's or service providers' own purposes. Counselling content is not transferred to language-model or other AI services; the existing translation function concerns only editorial legal texts (Section 6.17).

Chapter 8

Data subject rights

8.1 Identity verification

Organisational part — maintained by the platform operator (contractual documents) — editing in the administration area will follow —

This section describes the organisation, decision-making processes and legal balancing by the organisation. It cannot be derived from source code and is therefore not maintained by ORISO. Until the organisation writes it, the document contains only the draft text, originally collapsed; the square brackets deliberately mark open fields.

Show draft text

Before handling a data subject request, the applicant's identity must be verified. At platform-operator level this is almost impossible: the platform knows neither real names nor verified contact details, only a system-generated pseudonym and, possibly, a voluntarily supplied, unverified email address. The operator therefore identifies the responsible counselling centre and asks it to verify identity; the centre compares the available details with the counselling history it knows and confirms the assignment through [channel, e.g. a reply in the counselling chat]. Additional options include [other means of identification, e.g. confirmation through the stored email address, naming case-specific characteristics]. If there are reasonable doubts about identity, additional information is requested under Section 17(3) KDG / Article 12(6) GDPR; if identity cannot be established, the request is refused with reasons. [Office/function] is responsible, and the processing deadline is [deadline].

8.3 Privacy notices and information channels

Organisational part — maintained by the platform operator (contractual documents) — editing in the administration area will follow —

This section describes the organisation, decision-making processes and legal balancing by the organisation. It cannot be derived from source code and is therefore not maintained by ORISO. Until the organisation writes it, the document contains only the draft text, originally collapsed; the square brackets deliberately mark open fields.

Show draft text

Privacy notices under Sections 15 and 16 KDG / Articles 13 and 14 GDPR are linked on the registration page before registration and permanently within the application after login; registration-free live chat displays them on the preceding entry page. Legal notice, privacy notice and consent text exist at every platform level; if a counselling centre has no local version, the organisation's version applies, otherwise the platform template — advice seekers therefore always see a complete set of legal texts. Counselling centres themselves provide information about their own processing, particularly case documentation outside the platform, through [channel, e.g. a counselling-chat notice, document upload, link to their own privacy notice]. Changes to privacy

notices are announced through [procedure, e.g. a notice at next login]. [Contact channel] is available for questions.

Technical part — maintained by ORISO — Sections 8.1, 8.3 and 8.11 are organisational —

Data subject rights under Sections 14 et seq. KDG / Articles 12 et seq. GDPR can be exercised against any joint controller; internal allocation is governed by the joint-controller agreement. The following sections describe, for each right, what is technically possible and what is technically impossible. This deliberately sharp distinction reflects that continuous end-to-end encryption, extensive data minimisation and self-deletion considerably strengthen rights in some areas but create technical limits in others that organisational effort cannot overcome.

Sections 8.1 (identity verification), 8.2 (specific features of anonymous use), 8.3 (privacy notices) and 8.11 (disclosure to investigative authorities) are operator-specific and maintained by the controller; prefilled drafts are available for 8.1, 8.3 and 8.11.

8.4 Right of access (Section 17 KDG / Article 15 GDPR)

Technically possible. The platform operator can provide access to the master and system data it stores. These principally include the system-generated pseudonym, any email address supplied, postcode, counselling-centre and specialist-area assignment, selected counselling topics and specialist-area details, registration and terms/privacy acceptance timestamps, two-factor authentication status, language and notification settings, counselling-session metadata (creation, assignment, archiving), notification-history entries and case-handover log entries concerning the person.

Technically impossible. The platform operator cannot provide access to counselling communication content — messages, files, voice messages, video and audio conversations. These exist only as ciphertext; decryption keys are held solely on participants' devices (Section 6.9). The operator can neither read nor export this content nor include it in an access response. Advice seekers, however, can see the full content in their application at any time; access to counselling content is therefore effectively provided by the application itself and, where necessary, the counselling centre.

Limit that must be stated honestly. Two datasets deserve particular mention because they contain data about an advice seeker outside their own counselling room: the team discussion in which counsellors discuss an enquiry not yet accepted, and the free-text reason in the case-handover procedure. Neither is visible to the advice seeker. Handover free text is available to the controller in plaintext and can therefore be disclosed; team-discussion content cannot, for the same cryptographic reasons as counselling content — only metadata (room existence, time, participating professionals) can be disclosed. For access requests this means access must be granted but cannot include the substance of colleagues' discussion. This restriction must be explicitly stated in the response and must not be hidden behind general wording.

Procedural note. Access requires verification of the applicant's identity, which the platform deliberately does not know; identity verification under Section 8.1 must therefore precede it and can practically only be performed through the counselling centre.

8.5 Right to rectification (Section 18 KDG / Article 16 GDPR)

Technically possible. Advice seekers can directly change their email address, password, language, notification settings and second factor themselves in the application. Counsellors and administrative roles have names, work email addresses, absence notices and assignments changed through their administration.

Practically limited. Other details are either system-generated (pseudonym, account identifier) or document actual system use (timestamps, session status, log entries). Such documentation data cannot be rectified because a change would make the documented event inaccurate; instead they are deleted after their retention period. The postcode can be changed; its substantive accuracy is

not checked by the system anyway.

Technically impossible. Rectification of counselling content by the platform operator is excluded. Advice seekers can, however, delete their own messages and send them again; this is the more effective practical route.

8.6 Right to erasure (Section 19 KDG / Article 17 GDPR)

Technically possible — designed to be particularly privacy-friendly. Advice seekers can independently and immediately delete individual messages and their entire account without applying to the controller. Account deletion includes a 48-hour protection window with read-only access to guard against accidental action, followed by automated execution. The deletion run removes the identity account, chat account (including an explicit deletion marker and room cleanup on the chat server), sessions and additional session data, topic and supervision assignments, case-handover requests, agency assignments, the pseudonym-registry entry, mobile-device identifiers and finally the account record. Anonymous accounts are automatically deleted after a short period without action by the data subject.

During onboarding, counsellors are informed that advice seekers may remove counselling data at any time without notice.

Technically impossible. The server operator cannot identify an individual message within an encrypted history and therefore cannot selectively delete it; complete rooms and their media can be removed. Individual messages are therefore deleted solely by the data subject themselves in the application.

Limits that must be stated honestly.

Datasets not covered. Account deletion currently does not cover in-app notification history, server-stored message drafts, pseudonymised counsellor message statistics, the archive of invitation emails sent, the inactivity-notification audit log or a person-to-chat-room mapping table remaining from migration. Closing these gaps is listed as a measure (Section 6.18); until then deletion is incomplete and must not be described as complete.

Reference record after deletion. A reference record retaining the full former account identifier remains after execution to resolve references in surviving records. Personal identifiability therefore survives deletion. A retention period must be defined or the identifier itself pseudonymised.

Backups. Deleted data remain in backups until the backup periods expire (30 days for full backups, seven days for continuous chat-service log backups). This is usual for staggered backups and must be documented in the deletion concept.

Log and evidentiary data. Log and evidentiary data with independent legal bases and retention periods are excluded from deletion requests (Section 7.5).

Counsellors. Counsellor accounts cannot be deleted during active service; termination of the service relationship with the organisation is decisive.

Team-discussion archive. Closed discussion rooms remain readable; a retention period must be defined.

8.7 Right to restriction of processing (Section 20 KDG / Article 18 GDPR)

Not technically implementable in its actual form. The platform does not support marking data as “stored only, not processed”; such a marker would also be ineffective for end-to-end encrypted content because the controller does not process it anyway.

Technically possible as a functional equivalent. Available options are suspending deletion for three to at most twelve months with a documented reason, preserving the dataset unchanged; the

48-hour read window in the deletion process, during which no further writing occurs; and blocking or deleting the account through the controller. Temporary account deactivation is additionally available for counsellors and is the closest practical equivalent to restriction.

Advice seekers cannot block their own accounts, only delete them. A restriction request must therefore be directed to the controller, who arranges blocking.

8.8 Right to data portability (Section 22 KDG / Article 20 GDPR)

Technically possible. Consent-based master data (pseudonym, email address, postcode, topic and specialist-area assignment, voluntary additional details and consent timestamps) can be provided in a structured, commonly used, machine-readable format.

Technically impossible. A machine-readable export of counselling content by the controller is excluded because it cannot decrypt that content. Advice seekers can see the full content in the application and save it on their device; no server-generated export exists. A client-side export of decrypted history should be considered as a possible product measure, but is not currently implemented. This restriction is the direct counterpart of encryption — the price of protection that would not otherwise exist — and is therefore openly stated rather than minimised.

The right generally does not apply to counsellors because their data are based neither on consent nor on a contract between them and the platform operator.

8.9 Right to object (Section 23 KDG / Article 21 GDPR)

Practically narrow scope. Objection addresses processing based on legitimate interests. For advice seekers, this only concerns technical usage and operational data (Section 7.2, paragraph 1). These are essential for operation; an objection would mean the platform could no longer be used. It therefore amounts to ending use and exercising the erasure right under Section 8.6. There is no advertising or marketing processing subject to unconditional objection.

For counsellors, compelling legitimate grounds of the controller generally prevail because counselling and accountability are impossible without accounts, role assignments and logging. Objections must be assessed individually, particularly concerning activity statistics (Section 6.15), where the performance-related nature requires careful documentation of the balancing exercise.

8.10 Right to withdraw consent (Section 8(6) KDG / Article 7(3) GDPR)

Technically possible and immediately effective. Withdrawal may be declared to the counselling centre or platform operator. Since registration and counselling rely on consent, withdrawal removes their basis; account deletion, which the data subject can initiate themselves, implements it directly. Partial withdrawal is possible for voluntary additional details: email address and two-factor authentication can be removed at any time by the user.

The lawfulness of processing before withdrawal is unaffected. Withdrawal does not apply to counsellors because their processing is not based on consent (Section 7.3).

Evidence of consent — open issue. Acceptance of terms and privacy notices is stored with a timestamp. A client-side-only confirmation check is documented for part of the registration flow; server-enforced evidence must be ensured to fulfil the burden of proof under Section 8(2) KDG / Article 7(1) GDPR. This is listed as a measure.

8.12 Summary assessment by right

| Right | KDG provision (GDPR) | Implementability

| Access | Section 17 KDG (Article 15) | limited — master and system data yes, counselling content technically no

| Rectification | Section 18 KDG (Article 16) | limited — editable fields self-managed, documentation data not rectifiable

| Erasure | Section 19 KDG (Article 17) | largely — self-deletion of messages and account; identified residual datasets open

| Restriction | Section 20 KDG (Article 18) | limited — blocking, deletion suspension or deactivation only

| Portability | Section 22 KDG (Article 20) | limited — master data exportable, counselling content not

| Objection | Section 23 KDG (Article 21) | hardly applicable in practice — operational data essential

| Withdrawal | Section 8(6) KDG (Article 7(3)) | complete — directly implemented through self-deletion

8.11 Escalation chain and disclosure to investigative authorities

Organisational part — maintained by the platform operator (contractual documents) — editing in the administration area will follow —

This section describes the organisation, decision-making processes and legal balancing by the organisation. It cannot be derived from source code and is therefore not maintained by ORISO. Until the organisation writes it, the document contains only the draft text, originally collapsed; the square brackets deliberately mark open fields.

Show draft text

If a reportable criminal offence is announced during counselling or an acute threat becomes apparent (“worst case”), a jointly developed action recommendation provides this responsibility chain: (1) the counsellor immediately informs [counselling-centre management]; (2) [function] performs a professional threat assessment, consulting [specialist service] where necessary; (3) where Section 138 of the German Criminal Code or a child-welfare threat applies, the counselling centre, rather than the platform operator, forwards required information to [police / youth welfare office]; (4) [department management, data protection officer, organisation representative] are informed in parallel. Only message content viewed by the counsellor, the system-recorded timestamp and the processor’s address can be disclosed; advice seekers’ IP addresses are not retained in specialist datasets and therefore cannot be disclosed, and the platform operator has no plaintext counselling content because of end-to-end encryption. Separately, for data protection incidents under Section 33 KDG / Article 33 GDPR: notify [supervisory authority] within 72 hours through [reporting channel], internally alert [functions] within [deadline], with substitution by [function].

Chapter 9

Proportionality

9.1 Legitimate purpose

Organisational part — maintained by the platform operator (contractual documents) — editing in the administration area will follow —

This section describes the organisation, decision-making processes and legal balancing by the organisation. It cannot be derived from source code and is therefore not maintained by ORISO. Until the organisation writes it, the document contains only the draft text, originally collapsed; the

square brackets deliberately mark open fields.

Show draft text

Processing aims to enable accessible, confidential counselling independent of location for people seeking advice. [Controller's name] thereby fulfils its [statutory / legal / church] mandate to support people in situations of distress and conflict; the basis is [reference to mission statement, statutes or legal mandate]. The purpose is legitimate because it reduces barriers to access: it particularly reaches people who would not visit a counselling centre because of shame, mobility constraints, time constraints or fear of stigmatisation. Processing additionally aims to offer digital counselling with the same quality and confidentiality as in-person counselling.

9.2 Suitability

Organisational part — maintained by the platform operator (contractual documents) — editing in the administration area will follow —

This section describes the organisation, decision-making processes and legal balancing by the organisation. It cannot be derived from source code and is therefore not maintained by ORISO. Until the organisation writes it, the document contains only the draft text, originally collapsed; the square brackets deliberately mark open fields.

Show draft text

Processing is suitable for achieving the purpose. A central platform discoverable under an established name and usable under a pseudonym demonstrably reaches people who would otherwise not seek help; this is supported by [metrics, e.g. number of first enquiries, proportion of anonymous first contacts, survey/evaluation dated [date]]. The technical procedures used are suitable for actually providing the promised confidentiality: counselling content is transmitted and stored with end-to-end encryption, so neither the operator nor its service providers can access it. The unified platform also enables common standards of quality, security and continuing education that individual organisations could not achieve separately.

9.3 Necessity

Organisational part — maintained by the platform operator (contractual documents) — editing in the administration area will follow —

This section describes the organisation, decision-making processes and legal balancing by the organisation. It cannot be derived from source code and is therefore not maintained by ORISO. Until the organisation writes it, the document contains only the draft text, originally collapsed; the square brackets deliberately mark open fields.

Show draft text

No less intrusive, equally suitable means is available. The following were assessed and rejected: (1) dispensing with all registration — this would make continuous counselling across multiple contacts and development of a trusting relationship impossible; registration-free live chat remains available for initial contact as a less intrusive option; (2) decentralised individual organisation solutions — these fragment the service, exceed smaller organisations' technical and financial capabilities, and substantially reduce discoverability for advice seekers; (3) [other assessed alternative, e.g. telephone-only or in-person counselling] — [reason for rejection]. The scope of data collected is limited to what is necessary: only the postcode is mandatory to assign the responsible counselling centre; the username is system-generated and all other information is voluntary.

9.4 Appropriateness

Organisational part — maintained by the platform operator (contractual documents) — editing in the administration area will follow —

This section describes the organisation, decision-making processes and legal balancing by the organisation. It cannot be derived from source code and is therefore not maintained by ORISO. Until the organisation writes it, the document contains only the draft text, originally collapsed; the square brackets deliberately mark open fields.

Show draft text

The balancing of interests favours processing. The sensitivity of counselling content and the particular vulnerability of some advice seekers weigh in favour of data subjects; the service's benefit and depth of protective measures weigh in favour of processing. Four aspects are decisive: (1) voluntary participation — use, registration and all additional information are voluntary, and withdrawal is effective immediately at any time; (2) data minimisation — the username is system-generated, only the postcode is mandatory, and there is no tracking, profiling or advertising; (3) limited processing activities — the operator does not evaluate counselling data; statistics are aggregated and subject to small-cell suppression; (4) extensive technical and organisational measures — particularly continuous end-to-end encryption of all counselling formats, self-deletion of messages and accounts, mandatory two-factor authentication for counsellors and the logged handover procedure. Remaining risks and their associated measures are detailed in the risk analysis (Annex 1); issues not yet finally addressed are [list of open issues taken from Chapter 10].

Chapter 10

Result of the data protection impact assessment

Technical part — maintained by ORISO —

The processing activity “Provision and technical operation of the online counselling platform” can be implemented in the form described in Chapter 6 — subject to the measures in the risk analysis (Annex 1) and the retention periods in the deletion concept (Annex 2). Without these two annexes, the substantive result is incomplete; approval is conditional on the measures specified there.

The decisive factors are the technical safeguards excluding access by the controller and its processors to actual counselling content: continuous, non-disableable end-to-end encryption of all counselling formats, including files, voice messages and media streams; data minimisation through system-generated pseudonyms; complete absence of tracking and third-party telemetry; disabled federation; self-deletion of messages and accounts; and small-cell suppression and pseudonymisation in statistics. Compared with the predecessor platform, these represent a substantial improvement in protection in the central areas of messages, files, video and anonymous live chat.

At the same time, this result is explicitly conditional. It assumes that the open issues identified in this DPIA are resolved before production operation. The conditions are:

Clarification of the backup path to an external source-code management system (Section 6.17). If this path is active, it constitutes an impermissible third-country transfer with a practically undeletable history; approval is withdrawn until it is disabled.

Closing deletion gaps and defining retention periods for the datasets identified in Section 6.18, log data and chat-service media.

Hardening chat-service operation: disabling open registration, restoring rate limits, authenticated media downloads and deciding whether to disable online status.

Separating operational and data-access permissions for platform administration and allowing only write access to organisation credentials, with encryption at rest (Section 6.16).

Replacing external STUN servers and enabling the IP-free logging listener in identity management (Sections 6.6 and 6.10).

Demonstrating identity-management configuration on the live system (password policy, login protection, token lifetimes, two-factor enforcement) and aligning the DPIA with the demonstrated state (Section 6.5).

Resolving open operator questions with the hosting provider: encryption at rest, backup location and encryption, production access and administration concept, subprocessors. Without these answers, the chapter on technical and organisational measures remains incomplete.

Decision on the media scanning proxy (Section 6.12): while no automated scan is active, a medium residual risk remains that must be recorded as such in the risk analysis and made transparent to organisations.

This DPIA does not cover functions that have been decided upon but not delivered — particularly appointment management (Section 6.2.6) and the media scanning proxy. They will be assessed through an update to this document upon delivery. Likewise, activation of statistics event publication, push notifications or the parked device must each be separately assessed before commissioning.

This DPIA is designed as a living document: it is updated with each release version, and every technical statement can be traced to source code, configuration or an architectural decision. Routine review takes place at the time stated in the document header and in response to substantial changes in processing.

The final proportionality assessment (Chapter 9) and approval by the controller's data protection officer must be added by the operator.

Annex 1

Annex 1 — risks and measures (draft)

Technical part — maintained by ORISO

Risks and measures carry stable identifiers (assigned once, never renumbered), making them precisely referenceable in activities and audits. Full matrix: Annex 1 — risk analysis (in preparation). Extract of the current source baseline:

| ID | Risk | Assessment | Measures (source baseline) | Residual risk

| R-001 | Unauthorised access to counselling content by operator or providers | High | M-001 Megolm E2EE continuously enabled, no unencrypted sending path · M-002 externally audited implementation (vodozamac) · M-003 AES-256 file encryption without metadata upload · M-004 federation disabled | Low — administrative server functions exist; confidentiality within the counselling centre is bounded by access control (sections 5.3/5.7)

| R-002 | Malware or unlawful images transmitted through media uploads | Medium | M-005 blur and click-to-reveal in anonymous live chat (fail-closed verdict, interim measure) · M-006 format validation and size limit for editorial uploads · M-007 fail-closed scanning proxy as agreed target architecture (ADR-019, not in production) | Medium — until scanner commissioning

| R-003 | Account takeover through compromised credentials | Medium | M-008 2FA (authenticator app/email one-time code), enrolled for counsellors during invitation; exemption documented only · M-009 central hashed password storage (Keycloak) | Low

| R-004 | Re-identification from statistical evaluations | Medium | M-010 aggregates only with small-cell suppression (minimum 5, fail-closed) · M-011 HMAC-SHA256 pseudonymisation of counsellor statistics | Low

| R-005 | Loss of user key material (own history unreadable) | Medium | M-012 server-side encrypted key backup; recovery secret remains with user | Low

Annexes

Annex register

Organisational part — maintained by the platform operator (contract documents) — editing in the administration area to follow

This section describes the organisation, decision-making processes and legal balancing by the affiliated organisation. It cannot be derived from source code and is therefore not maintained by ORISO. Until the organisation prepares it, the document contains only draft text; square brackets deliberately mark unresolved fields.

Show draft text

This DPIA comprises: Annex 1 — risk analysis (risk/measure matrix with stable identifiers, dated [date]); Annex 2 — deletion concept (retention and deletion periods per category, including logs and backups, dated [date]); Annex 3 — joint controllership arrangement pursuant to § 28(1) sentence 2 KDG / Art. 26 GDPR with annexes [numbers]; Annex 4 — processing agreements with [hosting operator] and [development provider]; Annex 5 — record of processing activities pursuant to § 31 KDG / Art. 30 GDPR, extract; Annex 6 — [worst-case guidance / further annex]. Each annex is versioned independently; the edition specified in its header is authoritative.